

API Reference

Resilio — Mobile Mental Health Platform for Nepal | Milan Shrestha | ID: 23057135 |
02_Elaboration/API_Reference.md

Node.js / Express REST API. All endpoints require HTTPS. Authentication is via SuperTokens session token in the Authorization: Bearer <token> header unless otherwise noted.

Base URL (Development): `http://localhost:3000`

Base URL (Production): `https://resilio-api.vercel.app`

AUTHENTICATION ENDPOINTS

These endpoints implement the SuperTokens passwordless OTP and social login flows. The `/auth/*` routes are handled by the SuperTokens middleware; the `/auth/custom/*` routes are custom Resilio endpoints that sync authenticated users into Supabase.

Method	Endpoint	Auth	Description
POST	<code>/auth/signinup/code`</code>	None	Step 1 — Request OTP email (SuperTokens <code>createCode</code>)
POST	<code>/auth/signinup/code/consume`</code>	None	Step 2 — Verify OTP and obtain access token (SuperTokens <code>consumeCode</code>)
POST	<code>/auth/passwordless/complete`</code>	Bearer token	Step 3 — Sync authenticated user into Supabase; returns user profile and role
POST	<code>/auth/signinup`</code>	None	Google/Facebook Sign-In — SuperTokens <code>thirdparty</code> flow
POST	<code>/auth/signout`</code>	Bearer token	Invalidate SuperTokens session

Request/Response: POST `/auth/passwordless/complete`

Request:

```
{
  "email": "user@example.com"
}
```

Response (200):

```
{
  "user": {
    "id": "uuid",
    "email": "user@example.com",
    "role": "user",
    "createdAt": "2025-01-15T10:00:00Z"
  },
  "isNewUser": true
}
```

USER ENDPOINTS

Method	Endpoint	Auth	Description
GET	/users/me	Bearer	Get current authenticated user's profile
PUT	/users/me	Bearer	Update current user's profile (name, avatar, bio)
DELETE	/users/me	Bearer	Delete account and all associated data (GDPR/privacy compliance)
GET	/users/me/preferences	Bearer	Get user's app preferences
PUT	/users/me/preferences	Bearer	Update preferences (language, notification settings)

THERAPIST ENDPOINTS

Public (Customer-facing)

Method	Endpoint	Auth	Description
GET	<code>/therapists`</code>	Bearer	List all verified therapists; supports query params: <code>?specialisation=&language;=&maxFee;=`</code>
GET	<code>/therapists/:id`</code>	Bearer	Get single therapist profile
GET	<code>/therapists/:id/availability`</code>	Bearer	Get available slots for a therapist; <code>?date=YYYY-MM-DD`</code>
GET	<code>/therapists/recommended`</code>	Bearer	Get therapist recommendations based on user's matching questionnaire

Therapist Self-Management

Method	Endpoint	Auth	Description
POST	<code>/therapists/profile`</code>	Bearer (therapist)	Create therapist profile and submit for verification
PUT	<code>/therapists/profile`</code>	Bearer (therapist)	Update therapist profile details
GET	<code>/therapists/me/appointments`</code>	Bearer (therapist)	List all appointments for the authenticated therapist
GET	<code>/therapists/me/patients`</code>	Bearer (therapist)	List all patients who have had sessions with this therapist
GET	<code>/therapists/me/earnings`</code>	Bearer (therapist)	Get earnings summary (total, per-session breakdown)
POST	<code>/therapists/availability`</code>	Bearer (therapist)	Set available time slots
DELETE	<code>/therapists/availability/:slotId`</code>	Bearer (therapist)	Remove an availability slot

APPOINTMENT ENDPOINTS

Method	Endpoint	Auth	Description
POST	/appointments`	Bearer (customer)	Create a pending appointment record before payment
GET	/appointments`	Bearer	List appointments for the current user (filtered by role)
GET	/appointments/:id`	Bearer	Get single appointment details
PUT	/appointments/:id/cancel`	Bearer	Cancel appointment (customer or therapist)

Request/Response: POST /appointments

Request:

```
{
  "therapistId": "uuid",
  "scheduledTime": "2025-03-15T10:00:00Z",
  "meetingRoomId": "room_therapistId_timestamp"
}
```

Response (201):

```
{
  "id": "uuid",
  "patientId": "uuid",
  "therapistId": "uuid",
  "scheduledTime": "2025-03-15T10:00:00Z",
  "status": "pending",
  "paymentStatus": "pending",
  "meetingRoomId": "room_therapistId_timestamp"
}
```

PAYMENT ENDPOINTS

Method	Endpoint	Auth	Description
POST	<code>/payment/verify`</code>	Bearer	Verify eSewa payment callback; confirm appointment on success

Request/Response: POST /payment/verify

Request:

```
{
  "appointmentId": "uuid",
  "transactionId": "esewa-txn-ref",
  "totalAmount": "500"
}
```

Response (200):

```
{
  "success": true,
  "appointment": {
    "id": "uuid",
    "status": "confirmed",
    "paymentStatus": "paid",
    "paymentTransactionId": "esewa-txn-ref"
  }
}
```

MOOD ENTRIES ENDPOINTS

Method	Endpoint	Auth	Description
POST	<code>/mood`</code>	Bearer (customer)	Create a new mood log entry
GET	<code>/mood`</code>	Bearer (customer)	Get current user's mood history; <code>?days=7`</code> or <code>?days=30`</code>
GET	<code>/mood/:patientId`</code>	Bearer (therapist)	Get a patient's mood history (within therapist-patient relationship)

Request/Response: POST /mood

Request:

```
{
  "moodScore": 4,
  "moodLabel": "Happy",
  "note": "Had a productive day at work"
}
```

Response (201):

```
{
  "id": "uuid",
  "userId": "uuid",
  "moodScore": 4,
  "moodLabel": "Happy",
  "note": "Had a productive day at work",
  "loggedAt": "2025-03-15T18:00:00Z"
}
```

QUESTIONNAIRE ENDPOINTS

Method	Endpoint	Auth	Description
POST	<code>/questionnaires/phq9`</code>	Bearer (customer)	Submit PHQ-9 responses; returns total score and severity band
POST	<code>/questionnaires/gad7`</code>	Bearer (customer)	Submit GAD-7 responses; returns total score and severity band
GET	<code>/questionnaires/history`</code>	Bearer (customer)	Get current user's questionnaire history
GET	<code>/questionnaires/:patientId/history`</code>	Bearer (therapist)	Get a patient's questionnaire history (within relationship)

Request/Response: POST /questionnaires/phq9**Request:**

```
{
  "answers": [0, 1, 2, 1, 0, 3, 2, 1, 1]
}
```

Response (201):

```
{
  "id": "uuid",
  "type": "PHQ9",
  "totalScore": 11,
  "severityBand": "Moderate",
  "crisisAlert": false,
  "completedAt": "2025-03-15T19:00:00Z"
}
```

Note: If totalScore ≥ 20, crisisAlert: true is returned and the Flutter client displays the Nepal Mental Health Helpline notice.

CONTENT ENDPOINTS

Method	Endpoint	Auth	Description
GET	/content`	Bearer	List all published content; supports `?type=article&category;=anxiety`
GET	/content/:id`	Bearer	Get single content item (full article body, audio/video URL)
POST	/content`	Bearer (therapist)	Submit new content for admin review
PUT	/content/:id`	Bearer (therapist, own content)	Edit own unpublished content
DELETE	/content/:id`	Bearer (therapist, own content)	Delete own content
PUT	/content/:id/approve`	Bearer (admin)	Approve content for publication
PUT	/content/:id/reject`	Bearer (admin)	Reject content with reason

SUBSCRIPTION ENDPOINTS

Method	Endpoint	Auth	Description
GET	<code>/subscriptions/plans`</code>	None	List available subscription tiers (Free, Silver, Gold)
GET	<code>/subscriptions/me`</code>	Bearer	Get current user's active subscription
POST	<code>/subscriptions`</code>	Bearer (customer)	Create subscription after successful eSewa payment
DELETE	<code>/subscriptions/me`</code>	Bearer	Cancel subscription

GAME SESSIONS ENDPOINTS

Method	Endpoint	Auth	Description
POST	<code>/games/sessions`</code>	Bearer (customer)	Record a completed game session
GET	<code>/games/sessions`</code>	Bearer (customer)	Get current user's game session history
GET	<code>/games/achievements`</code>	Bearer (customer)	Get current user's unlocked achievements

FAVOURITES ENDPOINTS

Method	Endpoint	Auth	Description
POST	<code>/favourites`</code>	Bearer (customer)	Add content or therapist to favourites
DELETE	<code>/favourites/:id`</code>	Bearer (customer)	Remove from favourites
GET	<code>/favourites`</code>	Bearer (customer)	List all favourites

NOTIFICATION ENDPOINTS

Method	Endpoint	Auth	Description
GET	`/notifications`	Bearer	List notifications for current user
PUT	`/notifications/:id/read`	Bearer	Mark notification as read
POST	`/notifications/register-token`	Bearer	Register FCM device token for push notifications

ADMIN ENDPOINTS

Method	Endpoint	Auth	Description
GET	`/admin/therapists/pending`	Bearer (admin)	List therapist profiles awaiting verification
PUT	`/admin/therapists/:id/verify`	Bearer (admin)	Approve therapist registration
PUT	`/admin/therapists/:id/reject`	Bearer (admin)	Reject therapist registration
GET	`/admin/users`	Bearer (admin)	List all users with filters
DELETE	`/admin/users/:id`	Bearer (admin)	Deactivate user account
GET	`/admin/content/pending`	Bearer (admin)	List content items awaiting moderation
GET	`/admin/analytics`	Bearer (admin)	Get platform statistics (user counts, session counts, revenue)

APPOINTMENT MESSAGES ENDPOINTS

In-session messaging attached to a specific appointment (used during therapy sessions alongside the video call).

Method	Endpoint	Auth	Description
GET	<code>/appointments/:id/messages`</code>	Bearer	Get all messages for a specific appointment
POST	<code>/appointments/:id/messages`</code>	Bearer	Send a message within an active appointment session

Request/Response: POST /appointments/:id/messages

Request:

```
{
  "content": "I have been feeling anxious since last week.",
  "senderType": "user"
}
```

Response (201):

```
{
  "id": "uuid",
  "appointmentId": "uuid",
  "senderId": "uuid",
  "senderType": "user",
  "content": "I have been feeling anxious since last week.",
  "createdAt": "2025-03-10T14:32:00Z"
}
```

QUOTES ENDPOINTS

Daily inspirational quotes served on the customer home dashboard.

Method	Endpoint	Auth	Description
GET	<code>/quotes/daily`</code>	Bearer	Get today's daily quote
GET	<code>/quotes`</code>	Bearer	List all quotes (paginated)
POST	<code>/quotes`</code>	Bearer (admin)	Create a new quote
DELETE	<code>/quotes/:id`</code>	Bearer (admin)	Delete a quote

TIPS ENDPOINTS

Wellness tips served in the content hub.

Method	Endpoint	Auth	Description
GET	<code>/tips`</code>	Bearer	List all wellness tips
GET	<code>/tips/:id`</code>	Bearer	Get a specific tip
POST	<code>/tips`</code>	Bearer (admin/therapist)	Create a new tip
DELETE	<code>/tips/:id`</code>	Bearer (admin)	Delete a tip

PREFERENCES ENDPOINTS

User notification and app behaviour preferences.

Method	Endpoint	Auth	Description
GET	<code>/preferences`</code>	Bearer	Get current user's preferences
PUT	<code>/preferences`</code>	Bearer	Update user preferences

Request/Response: PUT /preferences

Request:

```
{
  "notificationsEnabled": true,
  "appointmentReminders": true,
  "moodReminders": true,
  "newsletterOptIn": false,
  "language": "en"
}
```

Response (200):

```
{
  "userId": "uuid",
  "notificationsEnabled": true,
  "appointmentReminders": true,
  "moodReminders": true,
  "newsletterOptIn": false,
  "language": "en",
  "updatedAt": "2025-03-15T09:00:00Z"
}
```

VIDEO COMMENTS ENDPOINTS

Comment threads on video content items.

Method	Endpoint	Auth	Description
GET	<code>/videos/:id/comments`</code>	Bearer	List comments for a video
POST	<code>/videos/:id/comments`</code>	Bearer	Post a comment on a video
DELETE	<code>/videos/:id/comments/:commentId`</code>	Bearer	Delete own comment (or admin)

ERROR RESPONSE FORMAT

All errors return the following structure:

```
{
  "error": "Human-readable error message",
  "code": "ERROR_CODE"
}
```

HTTP Status	Meaning
400	Bad Request — validation error in request body
401	Unauthorised — missing or invalid SuperTokens session token
403	Forbidden — authenticated but insufficient role permissions
404	Not Found — resource does not exist
409	Conflict — duplicate resource (e.g. double-booking, duplicate subscription)
500	Internal Server Error — unexpected backend error

AUTHENTICATION MIDDLEWARE

Every protected endpoint runs through two middleware layers:

```
// 1. SuperTokens session verification
router.use(verifySession());

// 2. Role-based access control
router.use(requireRole(['admin'])); // or 'therapist', 'user'
```

`requireRole` checks the `user_role` column in Supabase and returns 403 if the user's role is not in the allowed list.